

Quiz interactif - Sensibilisation aux vulnerabilites web

A importer dans Kahoot via "Creer un kahoot > Importer une feuille de calcul" (fichier source : quiz-kahoot.xlsx). La reponse correcte est surlignee en vert.

#	Question	Reponse 1	Reponse 2	Reponse 3	Reponse 4	Temps (s)
1	Un formulaire de connexion accepte l'entrée `admin' --` et vous connecte sans mot de passe. De quelle vulnérabilité s'agit-il ?	Cross-Site Scripting (XSS)	Injection SQL	Command Injection	CSRF	20
2	Quelle est la meilleure protection contre l'injection SQL ?	Filtrer les apostrophes à la main	Utiliser un pare-feu applicatif	Utiliser des requêtes paramétrées (prepared statements)	Chiffrer la base de données	20
3	Un site affiche directement dans la page le contenu du paramètre `?name=` sans l'échapper. Quel risque cela introduit-il ?	Déni de service	Cross-Site Scripting (XSS) réfléchi	Injection SQL	Path Traversal	20
4	Quel caractère shell permet d'enchaîner deux commandes dans une injection de commande ?	`#`	`%`	`;`	`@`	20
5	Pourquoi est-il dangereux de permettre l'upload d'un fichier sans vérifier son contenu ?	Cela ralentit uniquement le serveur	Le fichier peut contenir du code exécuté par le serveur	Cela ne pose aucun risque si le fichier est petit	Cela sature uniquement la bande passante	20
6	Que signifie l'acronyme SAST ?	Secure Access Security Token	Static Application Security Testing	System Authentication Security Test	Software Access Scan Tool	20
7	Dans ce TP, quel outil a été utilisé pour l'analyse statique du code (SAST) ?	Trivy	Dependabot	CodeQL	CTFd	20
8	Quel outil a scanné l'image Docker pour y trouver des vulnérabilités connues ?	CodeQL	Trivy	Dependabot	GitHub Actions	20
9	Quel outil ouvre automatiquement des pull requests pour mettre à jour des dépendances vulnérables ?	Trivy	CodeQL	Dependabot	CTFd	20

10	Dans une pipeline CI/CD, pourquoi est-il utile de faire échouer le build sur une vulnérabilité critique ?	Pour ralentir les développeurs	Pour empêcher le déploiement d'une image ou d'un code dangereux	Pour économiser des ressources serveur	Ce n'est jamais utile	20
11	Qu'est-ce que le principe DevSecOps ?	Confier toute la sécurité à une équipe externe	Faire la sécurité uniquement avant la mise en production	Intégrer la sécurité en continu, tout au long du cycle de développement	Un outil spécifique de scan de vulnérabilités	20
12	Un mot de passe ou une clé d'API écrite en dur dans le code source est un risque parce que :	Cela ralentit l'exécution du programme	Toute personne ayant accès au code (dépôt, historique git...) peut la récupérer	Cela empêche les tests automatiques	Ce n'est pas un risque si le dépôt est privé	20
13	Que recommande-t-on de faire face à une commande système construite avec une entrée utilisateur ?	Échapper uniquement les espaces	Utiliser `shell=True` pour plus de flexibilité	Appeler le programme avec des arguments séparés, sans passer par un shell	Convertir l'entrée en majuscules	20
14	Pourquoi est-il risqué d'utiliser une image Docker de base très ancienne (ex : `node:14`) ?	Elle consomme plus de mémoire	Elle contient des vulnérabilités connues, non corrigées, dans l'OS et les paquets systèmes	Elle est incompatible avec Docker Compose	Elle ne peut pas être publiée sur un registre	20
15	Dans un mini CTF, à quoi correspond le "flag" ?	Un drapeau décoratif affiché sur la plateforme	Une chaîne secrète prouvant qu'un challenge a été résolu avec succès	Le nom du joueur gagnant	Un type de vulnérabilité	20
16	Quelle est la différence principale entre SAST et DAST ?	Aucune, ce sont des synonymes	SAST analyse le code source sans l'exécuter ; DAST teste l'application en fonctionnement	SAST est plus rapide mais moins précis	DAST ne s'applique qu'aux applications mobiles	20
17	Un correctif Dependabot propose de passer d'une version majeure à une autre (ex : Express 4 → 5). Que faut-il faire avant de fusionner ?	Fusionner immédiatement, Dependabot ne se trompe jamais	Vérifier la compatibilité et faire tourner les tests avant de fusionner	Ignorer la pull request	Supprimer la dépendance	20